

## ROADMAP DE 6 MESES — Conformidade NIS2 para autarquias (Grupo B)

Para chegar ao mínimo demonstrável que invoca o art. 65.º RJC (dispensa de coimas) até Abril de 2027

| MÊS | FOCO             | ENTREGÁVEIS-CHAVE                                                                                                                                                                                                                                            | PEÇA QUE SAI                            |
|-----|------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------|
| 1   | Qualificação     | <ul style="list-style-type: none"><li>■ Auto-identificação no MyCiber</li><li>■ Despacho ponto de contacto</li><li>■ Classificação entidades operacionais</li><li>■ Lista art. 32.º (20 dias úteis)</li><li>■ Registo SMAS separado (se aplicável)</li></ul> | Comprovativo de registo + lista pública |
| 2   | Políticas-base   | <ul style="list-style-type: none"><li>■ Política segurança da informação</li><li>■ Política palavras-passe (NIST)</li><li>■ Política controlo de acessos</li><li>■ Política backups</li><li>■ Política gestão de incidentes</li></ul>                        | 5 políticas aprovadas por despacho      |
| 3   | Diagnóstico      | <ul style="list-style-type: none"><li>■ Inventário 20-40 activos críticos</li><li>■ Inventário 15-25 fornecedores</li><li>■ Matriz risco 15-25 entradas</li><li>■ Mapeamento activos × fornecedores</li><li>■ (A) Funções críticas (O.ID, O.PSI)</li></ul>   | Inventário + matriz completos           |
| 4   | Medidas técnicas | <ul style="list-style-type: none"><li>■ MFA em M365 / VPN / admin</li><li>■ Backups testados (1.º teste)</li><li>■ Backup air-gapped</li><li>■ Patches em dia</li><li>■ SPF + DKIM + DMARC</li><li>■ HTTPS em sites institucionais</li></ul>                 | Configurações técnicas documentadas     |
| 5   | Resposta         | <ul style="list-style-type: none"><li>■ Plano Continuidade Negócio (PCN)</li><li>■ Playbooks ransomware + data breach</li><li>■ Matriz de escalação afixada</li><li>■ Folha-resumo prazos afixada</li><li>■ Tabletop exercise interno</li></ul>              | PCN + playbooks + 1ª simulação          |
| 6   | Ciclo            | <ul style="list-style-type: none"><li>■ Auditoria interna</li><li>■ Plano de acções correctivas</li><li>■ 1.ª sessão de formação anual</li><li>■ Registo de presenças</li><li>■ Acta de revisão pela gestão</li></ul>                                        | Acta anual assinada pelo presidente     |

**Após o mês 6 — ciclo anual de manutenção:** Anual: revisão pela gestão, plano de formação, lista art. 32.º · Semestral: revisão das matrizes, teste do PCN · Trimestral: teste de backup, revisão de contas, refresher de formação · Mensal: patches, monitorização, logs.